BİLGİ SİSTEMLERİ GÜVENLİK VE DENETİM RAPORU: SecurePass Telecom

1. Yönetici Özeti

SecurePass Telecom merkezi kimlik doğrulama ve Active Directory altyapısı üzerinde gerçekleştirilen güvenlik denetimi sonucunda, sistem sahipleri tarafından beyan edilen güvenlik kontrolleri ile mevcut teknik yapılandırmalar arasında kritik seviyede uyumsuzluklar tespit edilmiştir. "Sektör standartlarında parola politikası", "MFA kullanımı", "Kullanılmayan hesap bulunmamaktadır" ve "Minimum yetkilendirme" gibi güvencelerin teknik ortamda uygulanmadığı; ortamın siber saldırılara karşı zayıf olduğu tespit edilmiştir.

2. Denetim Kapsamı

Bu denetim; kimlik doğrulama kontrollerinin değerlendirilmesi, parola güvenliğinin analizi, ayrıcalıklı erişimlerin incelenmesi, kullanıcı yaşam döngüsü ve Active Directory risklerinin belirlenmesi kapsamlarında gerçekleştirilmiştir.

3. Yapılan Testler

Kanıt olarak sağlanan veri setleri üzerinden log analizi (Event ID değerlendirmeleri), Hash analizi (NTLM, MD5, SHA256), Kerberos zafiyet analizi (AS-REP Roasting ve Kerberoasting) ile Yetkilendirme (IAM) ve Görevler Ayrılığı analizleri gerçekleştirilmiştir.

4. Tespit Edilen Kritik Bulgular

- **Parola Politikaları Zafiyetleri:** Sistem sahipleri parola politikalarının sektör standartlarında olduğunu beyan etmesine rağmen, Karmaşıklık (Complexity) zorunluluğunun devre dışı olduğu tespit edilmiştir. Hesap kilitleme eşiği (Lockout Threshold) ve süresinin "0" olması, sistemi Brute-Force saldırılarına açık hale getirmektedir. Parolaların geri döndürülebilir şifreleme (Reversible Encryption) ile saklanması çok kritik bir güvenlik ihlalidir.

- **Zayıf Parola Kullanımı ve MD5/NTLM Riski:** Zayıf parola kullanılmadığı beyan edilmesine rağmen, yapılan Hash analizlerinde yöneticilerin ve servis hesaplarının "Password123", "password", "123456", "letmein" ve "admin" gibi kolay tahmin edilebilir zayıf parolalar kullandığı doğrulanmıştır.Tespit edilen parolalar:

domainadmin:Password123/backupsvc:123456/helpdesk:password/admin:password/
developer:123456/backupsvc:letmein/helpdesk:admin/finance:123456789/
finance.manager:password123

- **MFA (Çok Faktörlü Kimlik Doğrulama) Eksikliği:** Kritik hesaplarda MFA'nın aktif olduğu beyan edilmişse de administrator, domainadmin, backupsvc, sqlsvc ve dış kaynak olan tempconsultant hesaplarında MFA'nın bulunmadığı tespit edilmiştir.

- **Kullanıcı Yaşam Döngüsü (Leaver/Joiner) İhlalleri:** "Kullanılmayan hesap bulunmamaktadır" güvencesine aykırı olarak, oldadmin (532 gün), intern2024 (680 gün) ve legacyuser (881 gün) hesaplarının sistemden silinmediği belirlenmiştir.

- **Ayrıcalıklı Hesapların Yanlış Yönetimi:** "En Az Yetki (Least Privilege)" prensibi ihlal edilerek; backupsvc, helpdesk, sqlsvc (servis hesapları) ve tempconsultant (dış danışman) hesaplarının en yetkili grup olan Domain Admins grubuna dahil edildiği görülmüştür.

- **Servis Hesapları ve Hesap Sahipliği (Accountability):** backupsvc, sqlsvc ve legacysvc parolalarının yıllardır değiştirilmediği; applinksvc ve syncsvc parolalarının ise hiç değiştirilmediği saptanmıştır. Ayrıca administrator, domainadmin ve backupsvc hesaplarının sahiplerinin (Owner) bilinmemesi hesap verilebilirliği ortadan kaldırmaktadır.
- **Hash Algoritmaları:**Kurumun "Hash algoritmaları güvenlidir" beyanı gerçeği yansıtmamaktadır. Sistemde miladı dolmuş MD5 ve zayıf şifreleme sunan RC4/NTLM yapılandırmalarının kullanılması, organizasyonun parola saklama altyapısının modern güvenlik standartlarından tamamen uzak olduğunu kanıtlamaktadır.

- **Şüpheli Log Aktiviteleri:** 103.81.25.11 IP adresi üzerinden aynı gün içerisinde hem insan (helpdesk, administrator) hem de makine servis hesaplarıyla (backupsvc, sqlsvc) başarılı girişler yapıldığı tespit edilmiştir. Bu durum, parolaların ele geçirildiğine ve sistemde yanal hareket (Lateral Movement) yapıldığına işaret etmektedir.

- **Kerberos Zafiyetleri:** Beyanların aksine sistemde Kerberoasting riskine açık SPN kayıtlı servis hesapları (websvcvb. HTTP üzerinden çalışanlar) ile AS-REP Roasting riskine açık kullanıcılar (tempconsultant ve eski hesaplar) bulunmaktadır.

5. Bonus

Mevcut zafiyetlerin oluşturduğu etkiyi ölçmek adına, "Bir saldırganın yalnızca backupsvc hesabını ele geçirmesi" senaryosu teknik olarak incelenmiş ve aşağıdaki sonuçlara varılmıştır:

- **Domain Admin Yetkisine Ulaşım:** backupsvc hesabı halihazırda "Domain Admins" grubunda yer aldığı için, saldırgan bu hesabı ele geçirdiği an doğrudan Domain Admin yetkisine kavuşmuş olur. Ekstra bir zafiyet sömürmesine gerek kalmaz.
- **Kerberoasting Riski:** İlgili hesabın MSSQLSvc için bir SPN kaydı bulunduğu tespit edilmiştir. Saldırgan yetki almadan önce bile bu hesabın biletini (TGS) çekip çevrimdışı kırma yöntemleriyle parolasını elde edebilir.Örn hash kırma.
- **Yanal Hareket (Lateral Movement):** Log analizinde tespit edilen uzak IP (103.81.25.11) etkinlikleri, saldırganın bu yetkili servisi kullanarak ağdaki diğer sunuculara ve sistemlere yatayda rahatça sıçrayabildiğini kanıtlamaktadır.
- **Tam Sistem İhlali (Domain Compromise):** Ayrıcalık yükseltme (Privilege Escalation) adımı, tasarım hatası sebebiyle zaten en baştan gerçekleşmiştir. Saldırgan bu hesap üzerinden tüm Active Directory ortamını ele geçirebilir, yeni yönetici hesapları oluşturabilir veya fidye yazılımı dağıtımı (Ransomware) yapabilir.

6. Denetçi Önerileri

1. **Parola Politikalarının Sıkılaştırılması:** Reversible Encryption derhal kapatılmalı, parola karmaşıklığı aktif edilmeli ve kilitlenme (lockout) eşikleri standartlara uygun (örneğin 5 hatalı deneme sonrası 15 dakika kilitleme) hale getirilmelidir.
2. **Kullanıcı Yaşam Döngüsü (IAM):** 90 günden fazla aktif olmayan (intern2024, legacyuser, oldadmin) tüm hesaplar derhal silinmeli veya disable duruma getirilmelidir. (Eğer personel işten çıkması olduysa tüm yetkili hesapları derhal inaktif edilmelidir.)
3. **MFA Zorunluluğu:** Domain Admins ve IT dışındaki danışmanlar (tempconsultant) dahil olmak üzere tüm ayrıcalıklı ve dış kaynaklı hesaplarda MFA ivedilikle aktif edilmelidir.
4. **En Az Yetki Prensibi:** backupsvc, sqlsvc, helpdesk ve tempconsultant hesapları Domain Admins grubundan çıkarılmalı, yalnızca görevlerini yapabilecekleri spesifik ve kısıtlı yetkilerle donatılmalıdır.
5. **Log ve Olay Müdahale (Incident Response):** 103.81.25.11 IP'sinden gelen çoklu yönetici/servis hesabı girişleri derhal siber güvenlik ekibi (SOC) tarafından incelenmeli, ihlal (breach) durumu değerlendirilip ortamdaki tehlike bertaraf edilmelidir.
6. **Personel Bilgisi ve Siber Farkındalık:**Çalışan IT ekibinin bilgilendirilmesi ve gerekli güvenlik farkındalığı eğitimi verilmelidir.Verilen güvenceler çoğunlukla yanlış veya yetersizdir.